



UNIVERSITY OF
LEICESTER

School of Computing and Mathematical Sciences

CO7201 Individual Project

Interim Report

**Risk Modelling and Analysis for IT Systems using
Probabilistic Graph Rewriting Rules**

Neel Vinod Lad

nvl2@student.le.ac.uk

249025520

Project Supervisor : Prof. Reiko Heckel

Principal Marker : Dr. Victoria Wright

Word Count : 1370

Date : 25-07-2025

DECLARATION

All sentences or passages quoted in this report, or computer code of any form whatsoever used and/or submitted at any stages, which are taken from other people's work have been specifically acknowledged by clear citation of the source, specifying author, work, date and page(s). Any part of my own written work, or software coding, which is substantially based upon other people's work, is duly accompanied by clear citation of the source, specifying author, work, date and page(s). I understand that failure to do this amounts to plagiarism and will be considered grounds for failure in this module and the degree examination as a whole.

Name: Neel Vinod Lad

Date: 27-06-2025

Contents

1. Requirements Status	3
2. Time-plan and Risk Plan	6

1. Requirements Status

The following is a tentative requirement list segregated by importance for the Risk Modelling and Analysis for IT Systems using Probabilistic Graph Rewriting Rules.

2.1 Essential Requirements

- 2.1.1 Foundational Literature and Tooling Review: Before developing a prototype, it is essential to build a strong foundational understanding of graph-based modeling and transformation within the context of software engineering. This includes a solid grasp of the MITRE ATT&CK framework for identifying and categorizing adversarial behaviors, as well as hands-on familiarity with graph rewriting tools such as GROOVE for pattern matching and rule application. Additionally, background knowledge of Continuous-Time Markov Decision Processes (CTMDPs) and probabilistic model checking—using tools like PRISM—is crucial for accurately simulating attack propagation and analyzing risk over time. These foundational elements are critical to effectively designing and implementing the proposed risk modeling system.

Status: [Partially Completed](#)

Details: Concepts covering graph-based modelling and transformation, understanding of MITRE ATT&CK framework and graph modeling procedures are covered to understand the rules generation part. Now for analytics part CTMDPs and probabilistic model checking is not fully covered yet.

- 2.1.2 Typed Attributed Multigraph Representation: The system must support modelling IT infrastructures as typed attributed multigraphs, including nodes (users, servers, devices, etc.), edges (relations), and attributes (e.g., *has_access_to*, *owns*, *runs_on*, *alerts* role).

Status: [Partially Completed](#) (As per no of rules are drafted refer section 2.1.3)

Details: Type graph and Host graph (Business Graph) have been finalised and validated across their respective schemas. Both graphs are kept to the level where rules (5/~15) have been derived to avoid complexity and easy to maintain in the Groove, graphs get updated as per new rules are fully finalised.

- 2.1.3 Formal Rule Specification Language: There must be a machine-readable format (e.g., YAML, JSON) for defining graph rewriting rules with vulnerability patterns, attack rates, and probabilistic outcomes.

Status: [Partially Completed](#)

Details: As of now, estimated 15 attack rules have been derived but it is kept in a separate file from the original JSON rules files, because I am working for a flexible schema of rules which supports rules generation in the Groove. Current JSON files have 5 rules for which schema, simulation in Groove and other modifications related to rules will be performed.

- 2.1.4 JSON to Groove Automation: An automated script which will generate Groove based notations for type graph, host graph and risk rules. The script should take consider all nodes, edges, relations, LHS pattern and RHS (outcomes) of risk rule will support Groove graph modeling syntax.

Status: Partially Completed

Details: Generation of type graph and host graph is successfully completed as they were straight-forward. However, the main challenge will be to generate rules and their outcomes in GROOVE because of its syntax which includes several keywords such as type, new, del, not as well criteria for differentiating an object which belongs to same class with different attributes will which change the relation with other nodes based on outcomes.

- 2.1.5 Probabilistic Risk Analytics: For each pattern match, the system must estimate risk using attack rates per year, outcome probabilities of attack, and costs to company.

Status: Not Started

Details: Rules generation and modeling is near to finish, soon started working with the Analytics part.

- 2.1.6. MITRE ATT&CK: Risk rules must be grounded in real-world attack techniques (e.g., MITRE ATT&CK).

Status: Completed

Details: Rules are generated based on MITRE ATT&CK as of now, but they are open to adapt changes as per type and business graph.

- 2.1.7 Model Consistency Checking: The system must validate that the graph and rules are consistent and compatible for matching.

Status: Completed

Details: Consistency among the graph and rules is successfully achieved by an automated python script. It will open to modify as per updated in the graphs and rules.

2.2 Recommended Requirements

- 2.2.1 Graph Visualization: Visual representation of the business graph and attack surface (e.g., using, GROOVE, PlantUML) should be useful.

Status: Completed

Details: All drafted rules and its control program have will implement in the Groove as well analysed in the PlantUML. As per new, will be derived they will be implemented.

- 2.2.2 Modular Rule Organization: Rules should be organized by tactics/techniques or attack phases for easier management and extensibility.

Status: Completed

Details: For each rule, their LHS pattern (pre-conditions/ vulnerability pattern) and its RHS (post-conditions/outcomes) is separately defined for every rules.

- 2.2.3 Export/ Derive to Model Checker: Ability to export/derive the system model to tools like PRISM or STORM for formal CTMDP analysis should be implemented.

Status: Not Started

Details: Details: Rules generation and modeling is near to finish, soon started working with the Analytics part.

- 2.2.4 Continuous-Time Markov Decision Process (CTMDP) Integration: Formal semantics and simulation using CTMDP tools (e.g., PRISM, STORM) for advanced risk propagation analysis is desirable.

Status: Not Started

Details: Details: Rules generation and modeling is near to finish, soon started working with the Analytics part.

2.3 Optional Requirements

- 2.3.1 Use of NLP or LLMs for suggesting recovery or precautions: After analysing attack patterns its outcomes LLMs can be used to generate some suggestions for recovery and necessary precautions.

Status: Not Started

Details: Rules generation and modeling is near to finish, soon started working with the Analytics part as completion decisions will be made as per requirements.

- 2.3.2 Interactive Dashboard: GUI dashboard could provide an interactive exploration of the business graph and risk analytics.

Status: Partially Completed

Details: Derived rules can be visualized in the Groove as well as all the possible states can be explored and managed through the control program in the Groove, but for the Analytics part working with PRISM is on the way.

- 2.3.3 OCL-like Constraints: Support for expressing and enforcing may provide advanced constraints on pattern matching.

Status: Not Started

Details: Rules generation and modeling is near to finish along with rule schema is under-development. Once, the foundations is setup, constraints will be considered.

2. Time-plan and Risk Plan

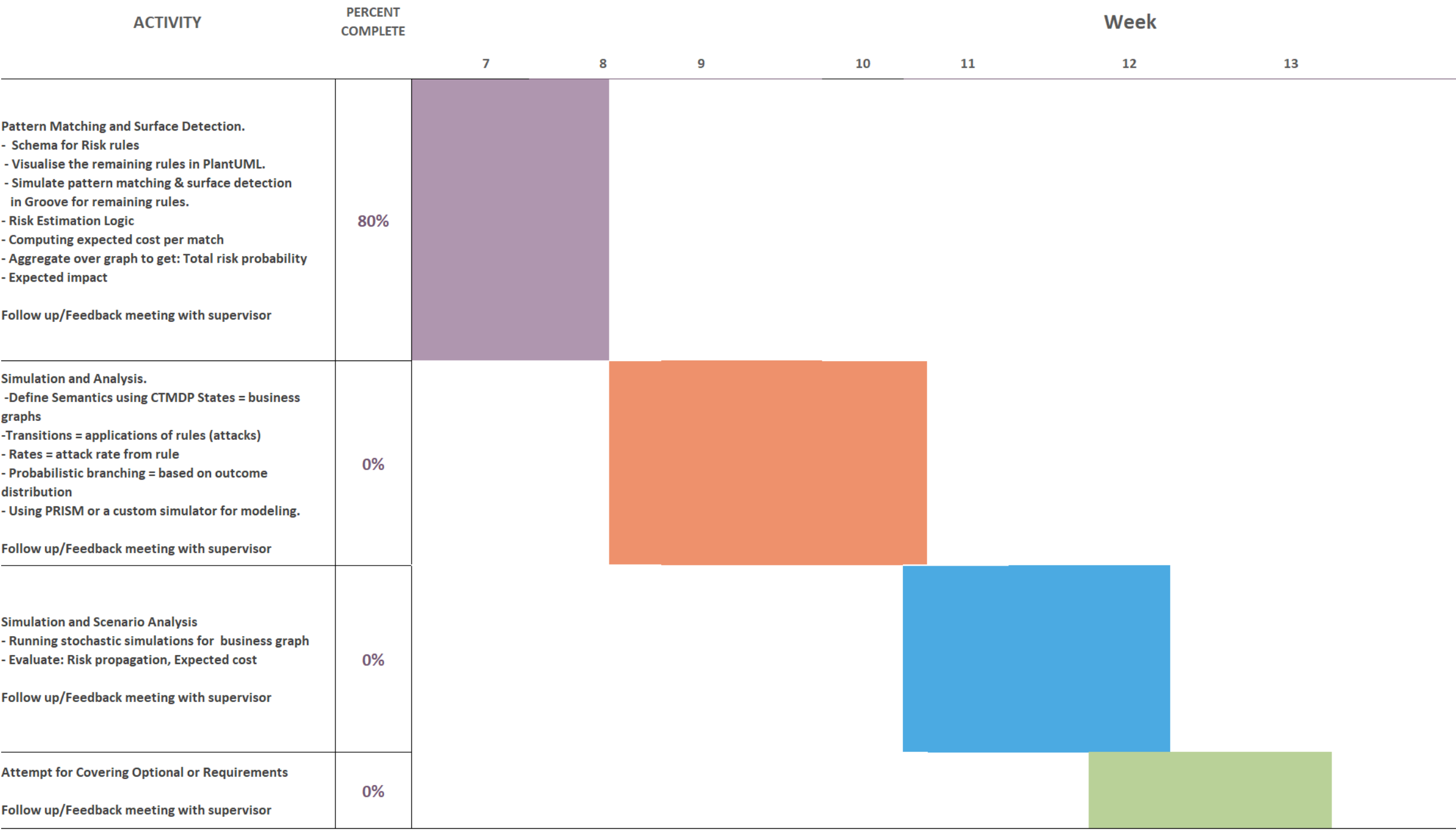


Figure 1: Estimated research and development time-plan for this study.

Risk Plan

These incoming risk assessment till now are adopted can be enhanced through research and development process:

1. Risk Identification

- 1.1 Data Quality and Consistency:** Inconsistencies between the business graph, risk rule specifications, and the typed graph (e.g., mismatched node types, attributes, or relations) may lead to incorrect pattern matching and analysis errors.
- 1.2 Scalability and Computational Complexity:** Modelling and analyzing the entire IT system at once can result in high computational demands, making the process slow or infeasible for large infrastructures.
- 1.3 Pattern Matching Errors:** Manual matching of risk rule patterns to the business graph is error-prone and time-consuming, increasing the risk of missed vulnerabilities or false positives.
- 1.4 Tool Integration and Usability:** Jumping directly into advanced tools like GROOVE without proper preparation may lead to inefficiencies, steep learning curves, or misconfigurations.
- 1.5 Design a Dynamic Schema:** Schema should be capable of mapping with Groove syntax which will helps in automated the process of drafting graph manually.
- 1.6 Visualization and Change Management:** Lack of clear visualization for rules and system structure can make it difficult to adapt to changes or communicate findings effectively.

2. Mitigation Strategies

- 2.1 Modular Modelling:** Instead of modelling the entire IT system at once, breaking down the infrastructure into smaller, manageable modules or domains. This modular approach reduces computational complexity and allows for focused, scalable analysis.
- 2.2 Automated Consistency Checking:** Developing a dynamic program to automatically compare nodes, attributes, relations, and sources across the business graph, risk rule specs, and typed graph. This tool will highlight missing or incorrect parameters, ensure consistency and reduce manual effort.
- 2.3 Incremental Visualization:** Before using advanced pattern matching tools like GROOVE, visualizing risk rules and system structure using adaptable tools such as PlantUML. This step makes it easier to adapt to changes, verify correctness, and set a solid foundation for subsequent analysis.
- 2.4 Phased Tool Adoption:** Gradually introducing advanced tools, starting with visualization and simple pattern matching, before moving to full automation and simulation. This reduces the risk of tool-related errors and allows for smoother integration.

- 2.5 Drafting Schema:** Taking a note of all used attributes, keywords and syntax structure of groove analysing with its each node, edges, and changes in the business graph as per outcomes of risk rules.
- 2.6 Continuous Review and Adaptation:** Regularly reviewing modelling choices, rule definitions, and analysis outputs, incorporating feedback and adapting to new requirements or threats as needed.